

Manual práctico de seguridad de inteligencia artificial

Edición para Oracle Cloud Infrastructure (OCI)

Una guía accesible sobre los fundamentos de la nube, las cargas de trabajo de IA, RAG, agentes, MCP, gobierno, pruebas, monitoreo y respuesta a incidentes.

Alberto (Al) Leiva

Versión 1.0 | julio de 2026

Use estas prácticas únicamente en cuentas, proyectos y sistemas propios o que esté autorizado a administrar. La capacidad técnica nunca crea autorización.

Tabla de contenido

En Microsoft Word, haga clic derecho sobre la tabla y seleccione Actualizar campo.

Tabla de contenido 2

Cómo utilizar este manual..... 3

Fundamentos de nube e inteligencia artificial..... 3

 Mapa de controles de la plataforma 3

Responsabilidad compartida y modelado de amenazas 4

Diseño seguro de cuenta y zona de aterrizaje..... 4

Identidad, acceso e identidades no humanas 5

Seguridad de red y del perímetro..... 5

Protección de datos, cifrado y privacidad 5

Registros, detección y postura de seguridad..... 6

Seguridad de cargas, contenedores y cadena de suministro..... 6

Ciclo de vida de IA y gestión de riesgo de modelos 7

IA generativa y seguridad de instrucciones 7

Seguridad de RAG 7

Agentes de IA, herramientas y MCP 8

Pruebas y red teaming..... 8

Gobierno, cumplimiento y mapeo de controles 8

Respuesta a incidentes de IA en la nube..... 9

Laboratorio práctico y seguro 9

 Paquete de evidencia10

Evidencia de auditoría y listas operativas10

Práctica profesional y orientación final.....10

Glosario10

Recursos oficiales y estudio adicional.....11

Apéndice: línea base mínima de controles12

Cómo utilizar este manual

Este manual presenta un método replicable para proteger las soluciones de inteligencia artificial en Oracle Cloud Infrastructure (OCI). Comienza con los fundamentos de la nube y avanza hacia identidad, datos, redes, IA generativa, generación aumentada por recuperación (RAG), agentes, Model Context Protocol (MCP), gobierno y operaciones.

Los nombres de los productos y las pantallas de las consolas cambian. La capacidad duradera consiste en comprender por qué existe un control, qué riesgo reduce, cómo se verifica y qué evidencia demuestra que funciona. Confirme siempre la disponibilidad regional, las licencias y la documentación vigente antes de utilizar un servicio en producción.

- Lea los capítulos en orden si está comenzando con seguridad en la nube.
- Si ya tiene experiencia, utilice las listas de verificación y las tablas de control como referencias de trabajo.
- Practique en un entorno aislado con datos sintéticos o públicos.
- Registre las decisiones, los responsables, las aprobaciones y los resultados de las pruebas.

Fundamentos de nube e inteligencia artificial

Oracle Cloud Infrastructure (OCI) proporciona servicios de cómputo, almacenamiento, redes, bases de datos, identidad, monitoreo y IA. Un sistema de IA combina esos componentes con modelos, instrucciones, datos, código, interfaces y personas. Proteger únicamente el modelo deja expuesta gran parte de la solución.

La estructura administrativa principal incluye tenancy, identity domains, compartments and regions. Utilícela para separar la producción del desarrollo, restringir privilegios, controlar costos y establecer límites de políticas en torno a las cargas sensibles.

Ruta segura de una solicitud de IA



Figura 1. Los controles protegen toda la ruta de una solicitud de IA.

Mapa de controles de la plataforma

Capa	Capacidad de la plataforma	Objetivo de seguridad
Organización	tenancy, identity domains, compartments and regions	Separación de entornos, responsables y alcance de políticas.
Identidad	OCI IAM policies, groups, dynamic groups, instance principals and resource principals	Federación, MFA, privilegio mínimo e identidad de cargas.

Capa	Capacidad de la plataforma	Objetivo de seguridad
Red	Virtual Cloud Networks (VCNs), subnets, Network Security Groups, security lists, gateways, Bastion and Web Application Firewall	Rutas privadas, entrada controlada y salida explícita.
Llaves y secretos	OCI Vault, Key Management and Secrets	Propiedad, rotación, separación de funciones y recuperación segura.
Registros	OCI Audit, Logging, Events, Notifications, Service Connector Hub and Logging Analytics	Evidencia protegida, detección e investigación.
Postura	Cloud Guard, Security Zones, Vulnerability Scanning Service and OS Management Hub	Hallazgos continuos de configuración y cargas.
Plataforma de IA	OCI Generative AI, OCI Generative AI Agents and OCI Data Science	Ciclo de modelos, evaluación, despliegue y gobierno.

- IaaS: el cliente administra los sistemas operativos, las aplicaciones, las identidades y los datos.
- PaaS: el proveedor administra una mayor parte de la plataforma, pero el cliente conserva la responsabilidad por acceso, configuración y datos.
- SaaS: el proveedor opera la aplicación, pero el cliente sigue siendo responsable de los usuarios, el uso compartido, los datos y las decisiones empresariales.
- Los servicios de IA implican responsabilidades relacionadas con el comportamiento del modelo, las instrucciones, la evaluación y la supervisión humana.

Responsabilidad compartida y modelado de amenazas

El proveedor protege las instalaciones y la plataforma del servicio. El cliente protege su cuenta, configuraciones, identidades, cargas de trabajo, datos y el uso de los resultados de IA. Un servicio administrado reduce las tareas operativas, pero no elimina la responsabilidad.

El modelado de amenazas analiza qué se está construyendo, qué podría fallar, qué controles existen y cómo se detectará una falla. Debe repetirse cuando cambien el modelo, los datos, los permisos de las herramientas, el despliegue o el propósito del negocio.

- Identifique los límites de confianza entre usuarios, aplicaciones, modelos, almacenes vectoriales, herramientas y servicios externos.
- Identifique entradas, salidas, credenciales, embeddings, registros y datos de entrenamiento sensibles.
- Considere abuso, inyección de instrucciones, autonomía excesiva, envenenamiento de datos, manejo inseguro de resultados y denegación de servicio.
- Asigne un responsable y un método de verificación medible para cada mitigación importante.

Diseño seguro de cuenta y zona de aterrizaje

Una zona de aterrizaje segura define la organización, la integración de identidad, los patrones de red, los registros, el cifrado, los límites preventivos y el acceso a la respuesta ante incidentes antes de desplegar aplicaciones. En OCI, organice los recursos mediante tenancy, identity domains, compartments y regions.

Separe la producción, el desarrollo, las herramientas de seguridad y los servicios compartidos. Centralice los registros en un lugar donde los administradores de cargas no puedan alterarlos silenciosamente. Utilice infraestructura como código para que los ajustes sean revisables y reproducibles.

- Documente a los propietarios y a los contactos de emergencia.
- Exija autenticación multifactor a los administradores humanos.
- Separe la producción de los entornos no productivos.
- Active la auditoría central antes de incorporar aplicaciones.
- Defina regiones, servicios, imágenes, patrones de llaves y etiquetas aprobadas.
- Pruebe la restauración de copias y el acceso de emergencia.

Identidad, acceso e identidades no humanas

OCI IAM policies, groups, dynamic groups, instance principals y resource principals determinan quién o qué puede acceder a los recursos. Las personas deben utilizar la federación y el MFA. Las cargas deben utilizar identidades nativas y credenciales de corta duración en lugar de llaves de API incorporadas.

Las identidades no humanas incluyen cuentas de servicio, identidades de carga, identidades de agentes, credenciales de CI/CD y tokens de integración. Suelen acumular privilegios y permanecer activas después de perder a su propietario; por eso requieren inventario, responsable, rotación y monitoreo.

- Conceda el privilegio mínimo en el alcance más reducido que resulte práctico.
- Separe las funciones administrativas, de despliegue, de ejecución y de auditoría.
- Evite cuentas compartidas y credenciales permanentes.
- Exija aprobación para permisos de alto riesgo y acceso a producción.
- Revise identidades inactivas, permisos no utilizados y llaves huérfanas.
- Asigne una identidad independiente a cada agente de IA y limite sus herramientas.

Seguridad de red y del perímetro

Utilice Virtual Cloud Networks (VCNs), subnets, Network Security Groups, Security Lists, gateways, Bastion y Web Application Firewall para crear límites de red en capas. Los endpoints privados reducen la exposición, pero "privado" no significa "confiable". Inspeccione el tráfico, limite las rutas y aplique la identidad incluso dentro de redes privadas.

Las aplicaciones de IA suelen llamar a endpoints de modelos, a almacenes de datos, a APIs SaaS y a herramientas. Defina una política de salida explícita para impedir que una instrucción maliciosa o un agente comprometido envíe información libremente a Internet.

- Deniegue el tráfico entrante de forma predeterminada y permita únicamente los flujos documentados.
- Use la conectividad privada con los servicios cuando esté disponible.
- Limite la administración a un bastión gestionado o a un acceso privado aprobado.
- Proteja endpoints públicos con WAF, defensa contra DDoS, límites de frecuencia y controles contra bots.
- Registre eventos de flujo y de perímetro y alerte ante destinos o volúmenes inusuales.
- Pruebe el DNS, el enrutamiento y la conmutación por error.

Protección de datos, cifrado y privacidad

Clasifique la información antes de enviarla a Object Storage, Autonomous Database, Database Services y Data Catalog, así como a instrucciones, trabajos de ajuste o índices vectoriales. Utilice OCI Vault, Key Management and

Secrets para proteger llaves y secretos. El cifrado es necesario, pero también lo son las decisiones de acceso, retención y eliminación.

Los embeddings pueden conservar el significado sensible, aunque no reproduzcan el texto original. Trate los almacenes vectoriales, conjuntos de evaluación, historiales de instrucciones y resultados según la clasificación de los datos de origen.

- Recolecte únicamente los datos necesarios para el propósito aprobado.
- Impida la divulgación de secretos y datos regulados en las instrucciones, salvo autorización explícita.
- Use llaves administradas por el cliente cuando lo exijan el riesgo, la regulación o el contrato.
- Separe a los administradores de llaves de los administradores de datos.
- Defina retención y eliminación verificables para instrucciones, resultados, registros y embeddings.
- Pruebe el cifrado de copias y los permisos de restauración.

Registros, detección y postura de seguridad

OCI Audit, Logging, Events, Notifications, Service Connector Hub y Logging Analytics proporcionan evidencia operativa y de seguridad. Cloud Guard, Security Zones, Vulnerability Scanning Service y OS Management Hub ayudan a identificar configuraciones débiles y riesgos en las cargas de trabajo. Envíe eventos importantes a un repositorio central protegido y, cuando corresponda, a un SIEM.

No registre instrucciones completas ni documentos recuperados de forma predeterminada. Equilibre la investigación con la privacidad y la exposición de secretos. Prefiera identificadores, hashes, clasificaciones, decisiones de política y fragmentos redactados.

- Inicios de sesión administrativos y cambios de políticas
- Ciclo de vida de credenciales, llaves y secretos
- Cambios de red, firewall y exposición pública
- Invocaciones de modelos, agentes y herramientas
- Bloqueos de controles, detección de inyección y resultados inseguros
- Acceso, exportación, eliminación y volumen inusual de datos
- Fallas del canal de registros y cambios de retención

Seguridad de cargas, contenedores y cadena de suministro

OCI Container Engine for Kubernetes (OKE), Container Instances y Registry pueden alojar aplicaciones de IA y servicios de apoyo. Proteja la canalización de construcción con el mismo cuidado que el entorno de ejecución: un clúster confiable no compensa un paquete, modelo o contenedor malicioso.

Utilice artefactos firmados, registros controlados, SBOM, análisis de vulnerabilidades y aprobaciones de despliegue. Fije versiones de dependencias y modelos cuando sea práctico y documente el origen y licencia de cada modelo y conjunto de datos.

- Use imágenes base mínimas y compatibles; ejecute sin privilegios de root.
- Analice el código, las dependencias, las imágenes, las plantillas de infraestructura y los secretos.
- Firme los artefactos y verifique las firmas durante el despliegue.
- Aplique políticas de admisión y restrinja los contenedores privilegiados.
- Separe las identidades de construcción y de ejecución.
- Monitoree las desviaciones de la configuración y de las versiones aprobadas.

Ciclo de vida de IA y gestión de riesgo de modelos

OCI Generative AI, OCI Generative AI Agents y OCI Data Science apoyan diferentes etapas del ciclo de IA. La seguridad comienza con un caso de uso documentado, un responsable y una clasificación de riesgo; no con la creación del endpoint.

Evalúe la calidad y la seguridad frente a la población y al entorno previstos. Un modelo que funciona en una demostración puede fallar con otros idiomas, instrucciones hostiles, datos incompletos o presión operativa real.

- Defina el propósito, los usos prohibidos y la autoridad humana de decisión.
- Registre el proveedor, la versión, el origen de los datos, la licencia y las limitaciones conocidas.
- Defina umbrales de aceptación para exactitud, seguridad, privacidad, latencia y costo.
- Pruebe sesgo, alucinación, inyección, fuga de datos y abuso.
- Exija una revisión independiente de riesgos y del negocio antes de liberar.
- Monitoree en producción y defina criterios de reversión.

Ciclo continuo de seguridad de IA



Figura 2. El gobierno y las pruebas se mantienen a lo largo de todo el ciclo.

IA generativa y seguridad de instrucciones

Una instrucción del sistema no constituye un límite de seguridad. Un atacante puede usar inyección directa o indirecta para modificar instrucciones, revelar información o activar herramientas. Trate toda entrada de usuario y contenido recuperado como no confiables.

Los guardrails reducen el riesgo, pero no garantizan un comportamiento seguro. Combine validación, filtrado, permisos limitados, validación de resultados, monitoreo y confirmación humana en las acciones importantes.

- Separe las instrucciones confiables del contenido no confiable.
- No incluya secretos en instrucciones ni en mensajes del sistema.
- Restrinja los formatos de salida y válidelos antes de utilizarlos.
- Use listas permitidas para herramientas, destinos y fuentes.
- Limite la frecuencia de las operaciones costosas o sensibles.
- Pruebe ataques multilingües, codificados, ofuscados e indirectos.

Seguridad de RAG

RAG fundamenta sus respuestas en documentos seleccionados, pero también crea un sistema de recuperación que debe aplicar una autorización antes de mostrar el contenido al modelo.

Un documento envenenado puede incluir instrucciones ocultas o persuasivas. Proteja la ingestión, conserve la procedencia, analice el contenido, aplique la autorización por documento y muestre citas para que el usuario verifique la respuesta.

- Apruebe e inventaríe los repositorios de origen.
- Analice malware, secretos, instrucciones encubiertas y formatos no compatibles.
- Conserve la fuente, el propietario, la clasificación, la versión y la fecha de ingestión.
- Filtre la recuperación según la identidad y el propósito del solicitante.
- Limite el contexto y evite la recuperación entre clientes.
- Evalúe la precisión, la autorización y la exactitud de las citas.

Agentes de IA, herramientas y MCP

Los agentes combinan el razonamiento del modelo con la memoria y las herramientas. MCP estandariza las conexiones entre clientes de IA y servidores que exponen recursos, instrucciones o herramientas. Esta facilidad aumenta la importancia de la autenticación, la autorización y los límites de confianza.

Trate cada servidor MCP y cada herramienta como software de integración privilegiado. Una búsqueda de solo lectura tiene un riesgo distinto al de una herramienta que envía correo, modifica firewalls o ejecuta código.

- Inventarié agentes, herramientas, servidores MCP, responsables y flujos de datos.
- Autentique el cliente y el servidor y utilice transporte cifrado.
- Asigne a cada agente una identidad propia con privilegios mínimos.
- Exija confirmación previa para acciones irreversibles, externas o de alto impacto.
- Valide los parámetros y los resultados; nunca ejecute el texto del modelo directamente.
- Registre la selección de la herramienta, los argumentos, la decisión, el resultado y la aprobación.
- Desactive las herramientas no utilizadas y mantenga un mecanismo de interrupción.

Pruebas y red teaming

Las pruebas deben demostrar que los controles funcionan, no solo que el modelo responde preguntas normales. Utilice entornos autorizados y datos sintéticos. Nunca pruebe sistemas de terceros sin permiso por escrito.

Combine la evaluación automatizada con la revisión humana. Promptfoo, Garak, PyRIT, Giskard e Inspect AI pueden organizar pruebas, pero sus resultados requieren interpretación y configuración segura.

- Prepare un plan basado en las amenazas y en criterios de éxito.
- Incluya casos normales, extremos, de abuso y hostiles.
- Pruebe varios idiomas y perfiles de usuario.
- Verifique el modelo y los controles que lo rodean.
- Registre instrucciones, versiones, ajustes, resultados y decisiones.
- Repita las pruebas cuando cambien el modelo, las instrucciones, los datos, las herramientas o las políticas.

Gobierno, cumplimiento y mapeo de controles

Utilice marcos para establecer un lenguaje común y adapte los controles al sistema real. NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, NIST CSF 2.0, privacidad y requisitos sectoriales pueden coexistir en un programa basado en evidencia.

Un mapeo no demuestra cumplimiento. La evidencia debe demostrar un diseño adecuado, un responsable asignado y un funcionamiento continuo.

- Gobernar: propiedad, políticas, apetito de riesgo y responsabilidad.
- Mapear: contexto, personas afectadas, datos, dependencias e impactos.
- Medir: calidad, seguridad, privacidad, equidad, resiliencia y costo.
- Gestionar: priorizar el tratamiento, aprobar el riesgo residual y vigilar los cambios.
- Mantener el inventario de sistemas, el registro de riesgos, la biblioteca de controles y la evidencia.

Respuesta a incidentes de IA en la nube

Los incidentes pueden incluir credenciales comprometidas, datos expuestos, resultados inseguros, fuentes envenenadas, automatización abusiva, costos inesperados o cambios en el proveedor del modelo. Amplíe el proceso normal para capturar el contexto de los modelos e instrucciones.

Conserve la evidencia sin recopilar innecesariamente contenido sensible. Coordine con seguridad, privacidad, asuntos legales, responsables de modelos, de negocio y de comunicaciones según la gravedad.

- Clasificar: confirmar el alcance, las identidades, los datos, los modelos, las herramientas y los usuarios.
- Contener: revocar credenciales, aislar endpoints, desactivar herramientas, detener la ingestión o revertir el modelo.
- Preservar: proteger registros, configuraciones, instrucciones, resultados, aprobaciones y versiones.
- Erradicar: retirar contenido malicioso, cerrar rutas y corregir la automatización.
- Recuperar: validar los controles, monitorear y obtener la aprobación del negocio.
- Aprender: actualizar pruebas, controles, documentación y capacitación.

Laboratorio práctico y seguro

Este laboratorio crea una línea base pequeña y poco productiva en OCI. Utilice únicamente datos sintéticos y servicios de costo mínimo. Elimine los recursos al terminar y confirme que los registros se conserven durante el periodo requerido.

El objetivo es practicar seguridad basada en evidencia: cada configuración debe generar una captura, una política exportada, un evento o un resultado que otra persona pueda revisar.

- Cree un límite no productivo mediante tenancy, identity domains, compartments y regions; agregue etiquetas de propietario, propósito, entorno y clasificación.
- Proteja al administrador mediante federación y MFA; cree una cuenta de uso diario con permisos limitados.
- Configure una red privada con Virtual Cloud Networks (VCNs), subnets, Network Security Groups, security lists, gateways, Bastion y Web Application Firewall; documente los flujos de entrada y salida permitidos.
- Active OCI Audit, Logging, Events, Notifications, Service Connector Hub y Logging Analytics y envíe eventos administrativos importantes al almacenamiento protegido.
- Configure OCI Vault, Key Management y Secrets; guarde un secreto de prueba y recupérela con una identidad de carga, no desde el código.
- Active o revise Cloud Guard, Security Zones, Vulnerability Scanning Service y OS Management Hub; investigue un hallazgo y registre la evidencia de la remediación.
- Implemente un experimento mínimo con OCI Generative AI, OCI Generative AI Agents y OCI Data Science, utilizando datos sintéticos y sin herramientas irreversibles.
- Cree diez pruebas normales y diez hostiles, que incluyan inyecciones, solicitudes de datos sensibles y resultados malformados.
- Revise el costo, la exposición pública, las identidades, los registros y los hallazgos; exporte un paquete pequeño de evidencia.
- Elimine los recursos temporales, revoque las credenciales y confirme que los registros esperados sigan disponibles.

Paquete de evidencia

- Diagrama de arquitectura
- Política de identidad exportada
- Resumen de reglas de red
- Prueba de registros
- Evidencia de llaves y secretos
- Hallazgo y remediación
- Informe de pruebas de IA
- Registro de limpieza

Evidencia de auditoría y listas operativas

La evidencia útil tiene fecha, autor, alcance y posibilidad de reproducción. Una captura puede omitir el alcance o el historial; combínala con la configuración exportada, los registros, los tickets, las aprobaciones y las pruebas.

Revise la evidencia según el nivel de riesgo. Los agentes de alto impacto y sistemas sensibles necesitan revisiones y monitoreo más frecuentes que una demostración con datos públicos.

- Arquitectura y diagrama de flujo de datos vigentes
- Inventario de modelos, conjuntos, agentes, herramientas e identidades no humanas
- Evaluación de riesgo y modelo de amenazas aprobados
- Políticas de acceso y revisiones periódicas
- Registros del ciclo de llaves, secretos y certificados
- Configuración y hallazgos de postura
- Resultados de evaluación y red teaming con remediación
- Ejercicios de incidentes y restauración

Práctica profesional y orientación final

La seguridad de la IA en la nube se aprende conectando la arquitectura, la identidad, los datos, el monitoreo, las pruebas y el gobierno. Cree proyectos pequeños y autorizados, y publique diagramas y mapeos sanitizados; nunca credenciales ni capturas sensibles.

Al presentar su trabajo, explique el propósito, los riesgos, las decisiones, la evidencia y el plan de mejora. Los empleadores valoran el juicio y la comunicación tanto como el conocimiento de la consola.

- Nunca afirme experiencia de producción que no posee.
- Indique con precisión qué diseñó, configuró, probó o revisó.
- Mantenga un diario de laboratorio y plantillas con control de versiones.
- Utilice la capacitación del proveedor, la documentación oficial y las cuentas seguras.
- Enseñe a otros; explicar un control es una excelente prueba de comprensión.

Glosario

Término	Significado
Agente de IA	Sistema que utiliza un modelo para planificar o seleccionar acciones e invocar herramientas.

Término	Significado
Embedding	Representación numérica utilizada para comparar similitud semántica.
Guardrail	Control técnico o de política destinado a limitar entradas, resultados o acciones.
Alucinación	Resultado aparentemente convincente que carece de respaldo o es incorrecto.
MCP	Model Context Protocol; estándar para conectar clientes de IA con recursos, instrucciones y herramientas.
Identidad no humana	Identidad utilizada por software, una carga, un servicio, una canalización o un agente.
Inyección de instrucciones	Instrucciones no confiables destinadas a cambiar el comportamiento o abusar capacidades conectadas.
RAG	Generación aumentada por recuperación; incorporación de material recuperado al contexto.
Almacén vectorial	Sistema que indexa y recupera embeddings.
Zero Trust	Enfoque que verifica explícitamente, limita el acceso y asume una posible intrusión.

Recursos oficiales y estudio adicional

Las funciones, los nombres, los precios y la disponibilidad regional pueden cambiar. Utilice estos puntos de partida oficiales y verifique la documentación aplicable a su cuenta y región.

- [OCI Security Guide](https://docs.oracle.com/en-us/iaas/Content/Security/Concepts/security_guide.htm) — https://docs.oracle.com/en-us/iaas/Content/Security/Concepts/security_guide.htm
- [OCI IAM documentation](https://docs.oracle.com/en-us/iaas/Content/Identity/home.htm) — <https://docs.oracle.com/en-us/iaas/Content/Identity/home.htm>
- [OCI Cloud Guard](https://docs.oracle.com/en-us/iaas/cloud-guard/home.htm) — <https://docs.oracle.com/en-us/iaas/cloud-guard/home.htm>
- [OCI Generative AI](https://docs.oracle.com/en-us/iaas/Content/generative-ai/home.htm) — <https://docs.oracle.com/en-us/iaas/Content/generative-ai/home.htm>
- [OCI Generative AI Agents](https://docs.oracle.com/en-us/iaas/Content/generative-ai-agents/home.htm) — <https://docs.oracle.com/en-us/iaas/Content/generative-ai-agents/home.htm>
- [OCI Logging](https://docs.oracle.com/en-us/iaas/Content/Logging/home.htm) — <https://docs.oracle.com/en-us/iaas/Content/Logging/home.htm>
- [NIST AI Risk Management Framework](https://www.nist.gov/itl/ai-risk-management-framework) — <https://www.nist.gov/itl/ai-risk-management-framework>
- [NIST Cybersecurity Framework 2.0](https://www.nist.gov/cyberframework) — <https://www.nist.gov/cyberframework>
- [OWASP Top 10 for LLM Applications](https://genai.owasp.org/llm-top-10/) — <https://genai.owasp.org/llm-top-10/>
- [MITRE ATLAS](https://atlas.mitre.org/) — <https://atlas.mitre.org/>
- [Model Context Protocol](https://modelcontextprotocol.io/) — <https://modelcontextprotocol.io/>

Este manual es una guía educativa; no constituye asesoría legal ni sustituye soporte del proveedor, requisitos contractuales o una evaluación formal de cumplimiento.

Apéndice: línea base mínima de controles

Dominio	Expectativa mínima	Evidencia de ejemplo
Gobierno	Caso aprobado, responsable, nivel de riesgo y usos prohibidos	Aprobación e inventario
Identidad	MFA, federación, privilegio mínimo e identidades separadas	Política y revisión de acceso
Datos	Clasificación, minimización, cifrado, retención y eliminación	Flujo, llaves y retención
Red	Acceso privado, entrada restringida y salida controlada	Diagrama, reglas y flujos
Seguridad de IA	Resistencia a inyección, validación, guardrails y aprobación humana	Evaluación y políticas
RAG	Fuentes aprobadas, procedencia y autorización previa	Inventario y pruebas de acceso
Agentes/MCP	Lista permitida, identidad propia, aprobación e interrupción	Inventario, registros y prueba
Operaciones	Registros centrales, alertas, respuesta, copias y reversión	Prueba de alerta, ejercicio y recuperación